情報処理安全確保支援士試験　科目A-2　中分類24 情報セキュリティマネジメント　#08

ISMSと管理策

JIS Q 27001 の「しなければならない」と、JIS Q 27002 の 93 の管理策

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、JIS Q 27001:2023・27002:2024・27014・27017、ISMS-AC など）を書いた。規格の本文は有料のため、箇条と管理策の名前をもとに Claude が要約した。過去問は IPA 公開の午前 II

全体像 シラバス案 中分類24 小分類5「ISMS」・小分類6「情報セキュリティ管理策」

1 ISMS の要求事項と認証
箇条4〜10・適用範囲・目的・適用宣言書・内部監査・マネジメントレビュー・是正処置、適合性評価制度、27014・27017

2 管理策のしくみ
4つのテーマ（組織・人・物理・技術）、属性、管理策タイプ（予防・検知・是正）、2022年版の新しい11の管理策

3 主な管理策
職務の分離・関係当局・脅威インテリジェンス・分類とラベル・人的管理策・クリアデスク・処分・特権・マスキング・DLP・クロック・環境の分離

過去の午前 II での出方

テーマ	出た回
27014 のガバナンスプロセス	R1秋
27017 にだけある管理策	R3秋
附属書 A に照らした監査の指摘	R3春

シラバス案は**管理策の名前を約120個**並べている。科目B では「どの管理策が不足しているか」を問われやすい。

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類24 小分類5・6／IPA 午前 II 令和元年度秋期 問7・令和3年度秋期 問9・令和3年度春期 問25

第1章

ISMS の要求事項と認証

箇条4〜10 を PDCA に重ねて覚える。

JIS Q 27001:2023 の箇条と PDCA

Plan
4 組織の状況／5 リーダーシップ／6 計画

Do
7 支援／8 運用

Check
9 パフォーマンス評価

Act
10 改善

箇条	主な要求
4 組織の状況	内外の課題、利害関係者のニーズ、**ISMS の適用範囲**（4.3）
5 リーダーシップ	トップのコミットメント、**情報セキュリティ方針**、役割・責任・権限
6 計画	リスクアセスメント（6.1.2）・リスク対応（6.1.3、**適用宣言書**）、**目的**（6.2）、変更の計画
7 支援	資源、力量、認識、コミュニケーション、文書化した情報
8 運用	運用の計画と管理、アセスメントと対応を**実施**
9 評価	監視・測定（9.1）、**内部監査**（9.2）、**マネジメントレビュー**（9.3）
10 改善	継続的改善（10.1）、**不適合と是正処置**（10.2）

附属書 A に 93 の管理策の一覧。2013年版の114から整理された。本文は他のマネジメントシステム規格と**共通の構造**（調和構造）。

出典：JIS Q 27001:2023（ISO/IEC 27001:2022）の箇条構成。表の要約は Claude

適用宣言書・内部監査・マネジメントレビュー・是正処置

言葉	だれが・何を
適用宣言書（SoA）	附属書 A の各管理策の**採否・理由・実施状況**。全部採用しなくてよい
情報セキュリティ目的	方針と整合し、測定可能な目標。何を・だれが・いつまでに・どう評価
内部監査	**監査員**が、規格と自組織のルールへの適合と有効性を確かめる。自分の仕事は監査しない
マネジメントレビュー	**トップ**が、ISMS が適切・妥当・有効かを見直し、改善や変更を決める
是正処置	不適合の**原因を除いて再発を防ぐ**。有効性もレビュー

不適合への対応の順番

1. 不適合を管理し、**修正**する（目の前の問題を直す）
2. 原因を明確にし、似た不適合がないか調べる
3. **是正処置**（原因を除き再発を防ぐ）を実施
4. 是正処置の**有効性をレビュー**し、必要なら ISMS を変更

> 担当者を罰しても、原因が仕組みにあれば再発する。2013年版の「予防処置」は箇条 6.1（リスクと機会）に吸収された。

出典：JIS Q 27001:2023 6.1.3 d)・6.2・9.2・9.3・10.2

ISMS 適合性評価制度と関連規格

認定機関（ISMS-AC）
認証機関を審査して認定

↓

認証機関
組織の ISMS を審査して認証

↓

組織
初回審査 → 毎年サーベイランス → 3年で再認証

> 認証は「仕組みが規格に合う」ことの証明で、事故が起きないことの保証ではない。

規格	中身
JIS Q 27000	用語（#06）
JIS Q 27001	要求事項（認証の基準）
JIS Q 27002	管理策の手引（認証の基準ではない）
JIS Q 27014	情報セキュリティガバナンス
JIS Q 27017	クラウドの管理策（利用者・提供者の対、**固有の管理策を追加**）

> **R3秋 問9：**27002 になく 27017 にあるのは「**クラウドサービス固有の**管理策」。BCMS（22301）、ガバナンス（27014）、制御システム（IEC 62443）は違う。

出典：ISMS-AC「ISMS 適合性評価制度の概要」／IPA 午前 II 令和3年度秋期 問9

情報セキュリティガバナンス（JIS Q 27014）

評価
現状と将来を評価
→
指示
目的・戦略を示す
→
モニタ
達成を評価できるようにする

コミュニケーション
利害関係者と情報を交換

保証（2015年版）
独立した監査・レビュー・認証を委託

2020年版（JIS Q 27014:2021）は評価・指示・モニタ・コミュニケーションの4つに整理。

R1秋 問7「モニタ」はどれか

選択肢	プロセス
目的・戦略について指示を与える	指示
戦略的目的の達成を評価することを可能にする	モニタ
独立した監査・レビュー・認証を委託	保証
利害関係者と情報を交換	コミュニケーション

ガバナンス（経営陣が方向付ける）と、マネジメント（管理層が実行する）を区別する。

出典：JIS Q 27014:2015・JIS Q 27014:2021／IPA 午前 II 令和元年度秋期 問7

第2章

管理策のしくみ（JIS Q 27002）

4つのテーマと、並べ替えに使う属性。

93 の管理策：4つのテーマと5つの属性

テーマ（箇条）	数
5 組織的管理策	37
6 人的管理策	8
7 物理的管理策	14
8 技術的管理策	34

管理策タイプ

予防	検知	是正
起きる前に防ぐ	起きたら見つける	被害を抑え戻す

属性	値
管理策タイプ	予防・検知・是正
情報セキュリティ特性	機密性・完全性・可用性
サイバーセキュリティ概念	識別・防御・検知・対応・復旧（CSF と同じ）
運用能力	資産管理・ID とアクセス管理など
セキュリティドメイン	ガバナンスとエコシステム・防御・防衛・回復力

例：ログの監視＝検知、教育＝予防、バックアップからの復元＝是正。

出典：JIS Q 27002:2024（ISO/IEC 27002:2022）4.2 テーマ及び属性・附属書 A

2022年版で新しく加わった 11 の管理策

番号	管理策	ねらい
5.7	脅威インテリジェンス	脅威の情報を集めて分析し、使える知見に（#09）
5.23	クラウドサービスの利用	取得・利用・管理・終了の手順（#06 責任共有）
5.30	事業継続のための ICT の備え	RTO・RPO を決め、復旧を試験（#22）
7.4	物理的セキュリティの監視	監視カメラ・侵入検知で施設を見張る
8.9	構成管理	ハード・ソフト・ネットワークの安全な設定を維持
8.10	情報の削除	不要になった情報を消す
8.11	データマスキング	機密データを隠す・置き換える
8.12	データ漏えい防止	DLP・外部送信の監視
8.16	監視活動	ネットワーク・システムの異常なふるまいを監視
8.23	ウェブ・フィルタリング	悪意のあるサイトへのアクセスを制限
8.28	セキュリティに配慮したコーディング	セキュアコーディングの原則を適用（#17）

出典：JIS Q 27002:2024 附属書 B／IPA「支援士試験 シラバス（案）」中分類24 小分類6 用語例（11 すべてが含まれる）

第3章

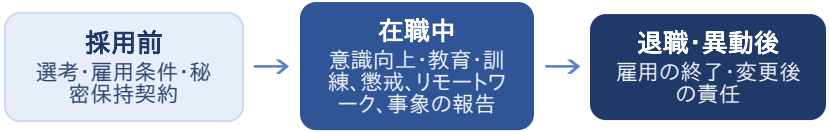
主な管理策

似た名前の管理策を、目的で区別する。

組織的管理策と人的管理策

管理策	ポイント
職務の分離	申請と承認、開発と本番導入を別の人に
関係当局との連絡	警察・監督官庁・個人情報保護委員会
専門組織との連絡	業界フォーラム・ISAC・CSIRT 協議会
情報の分類・ラベル付け	極秘・社外秘・公開と、表示
資産の目録・許容される利用・返却	何があるか・どう使うか・退職時に返す
情報の転送	手段ごとの規則・相手との合意
供給者関係	委託先との合意・ICT サプライチェーン・監視

人的管理策（8つ）は時間の順に



事象の報告は「だれでも、気付いたらすぐ」。報告した人を責めない雰囲気づくりも大切。

出典：JIS Q 27002:2024 箇条5・6／IPA「支援士試験 シラバス（案）」中分類24 小分類6 用語例

物理的管理策と技術的管理策

物理的管理策	ポイント
物理的セキュリティ境界・入退	区画を決め、入れる人を限る
クリアデスク・クリアスクリーン	机に放置しない、離席時は画面ロック
サポートユーティリティ	電源・空調・通信（UPS・自家発電）
ケーブル配線	盗聴・切断から守る
処分又は再利用	復元できない消去を確かめて記録

技術的管理策	ポイント
特権的アクセス権	必要な人に必要な間だけ、別アカウント
ソースコードへのアクセス	読み書きを制限し、変更を記録
クロックの同期	ログを突き合わせるため時刻をそろえる
ログ取得・監視活動	記録して守り、異常を見つける
ネットワークの分離	セグメントで分ける（#13）
暗号の利用	鍵の管理も含めて規則化（#15）

出典：JIS Q 27002:2024 箇条7・8

開発の管理策：R3春 問25 を読み解く

監査で見つかった状況	判断
セキュリティ機能の試験を**開発期間の終了後**に実施	**指摘（正解）**
セキュリティに配慮した開発環境で開発	**適合**
外部委託先の監督でセキュリティの観点を考慮	**適合**
パッケージの変更は必要なものに限定	**適合**

試験は**開発の途中**で行う（開発及び受入れにおけるセキュリティテスト）。

開発の管理策（2022年版）

- セキュリティに配慮した開発のライフサイクル
- アプリケーションセキュリティの要求事項
- セキュリティに配慮したコーディング（新）
- 開発及び受入れにおけるセキュリティテスト
- 外部委託による開発
- **開発・テスト・本番環境の分離**
- 変更管理
- **テスト用情報（本番の個人情報を使わない・マスキング）**

出典：IPA 午前 II 令和3年度春期 問25／JIS Q 27002:2024 8.25〜8.34

まとめ：本番での問われ方

箇条の場所：適用範囲＝4、方針＝5、リスク・SoA・目的＝6、運用で実施＝8、内部監査・マネジメントレビュー＝9、是正処置＝10。

規格の役割：27000 用語、27001 要求事項、27002 管理策の手引、27014 ガバナンス、27017 クラウド、27701 プライバシー（#07）。

管理策を当てる：場面（申請と承認が同じ人、ログの時刻がずれる、テストに本番データ、PC の返却）から管理策の名前を選ぶ。

タイプ：予防・検知・是正。属性の「サイバーセキュリティ概念」は CSF の5つ（GOVERN は含まない）。

出典：IPA 午前 II（このPDFの問題演習）／JIS Q 27001:2023・JIS Q 27002:2024